

</ "img src="../../../frontend/assets/logo-lockup.svg" alt="Cornell Deep" width="300">

مقارنة الأمان وسهولة الاستخدام بين السيناريوهات

الأرقام في هذا المستند مقيسة فعليًا من جدول `audit_trail` بعد تشغيل سويتات الاختبار (لا تقديرات). تُعاد الأرقام بأمر: `node scripts/export-scenario-comparison.js`.

1 ما الذي يفرضه كل سيناريو فعليًا في الكود

السيناريو	كلمة المرور	Mobile OTP	رمز بريد إضافي	RBAC	قاعدة التفعيل
1	✓	✗	✗	✗	الوضع الافتراضي
2	✓	✓	✗	✓	<code>scenario >= 2</code>
3	✓	✓	✓	✓	<code>scenario >= 2</code>

2 القياسات الحقيقية من سجل التدقيق

السيناريو	المحاولات	الناجحة	المرفوضة/المتوقفة	متوسط الخطر	متوسط زمن المعالجة
1	18	4	14	57.8	6.2
2	13	4	9	34.2	4.8
3	5	3	2	37	11.6

قراءة النتيجة: متوسط الخطر هنا يعكس طبيعة المحاولات التي اختارتها الاختبارات تحت كل سيناريو (السيناريو 1 استُخدم لتجربة الفشل المتتالي والحجب، فنسبة نجاحه منخفضة عمدًا). وهو ليس ترتيبًا أمنيًا: الأمان يأتي من تراكم البوابات المطلوبة، لا من متوسط الخطر.

3 الأمان مقابل سهولة الاستخدام

السيناريو	ما يحميه فعليًا	تكلفة الاستخدام	نقطة الضعف المتبقية
1	يقاوم فقط كلمات المرور المسروقة؛ لا يتحقق من هوية الجهاز.	خطوة واحدة بلا انتظار — أسرع منظور المستخدم	كلمة مرور واحدة مكشوفة = اختراق كامل
2	يوقف الرمز المسروق وحده: يحتاج المهاجم أيضًا إلى الهاتف.	خطوتان + قراءة رمز من الهاتف (30 ثانية صلاحية).	تصيّد OTP / إعادة توجيه الرسائل
3	طبقة خامسة: حتى لو سُرقت كلمة المرور والرمز، يفشل خادم البريد أو مسار RBAC.	أربع بوابات؛ قد يُطلب موافقة من جهاز آخر.	تعب MFA، وميل المستخدم لتجاوزه

4) كيف يخفف النظام التكلفة بدون خفض الحماية

التقنية	الموضع في الكود	أثرها على راحة المستخدم
كوكي <code>as360_trust</code> (سنة)	<code>cookie.js</code> · <code>auth.js</code>	الجهاز الموثوق يتجاوز خطوة OTP في زيارته التالية
<code>threat_factors</code> (5 دقائق)	<code>risk-engine.js</code>	الفشل المتتالي يرفع الخطر مؤقتًا ثم يعود للنظام
نطاقات الخطر ($69 \geq$ / $30 \geq$)	<code>config.js</code>	المستخدم الموثوق لا يرى أي خطوة إضافية
موافقة عبر جهاز آخر	قناة <code><cross:uid</code> · <code>events.js</code>	يصل التحدي إلى الجهاز الموثوق بدل جهاز المهاجم

5) مؤشرات الخطر الشائعة في السجل

التكرار	عوامل الخطر
12	BASELINE
6	ACCOUNT_LOCKED
3	NEW_IP + UNRECOGNIZED_DEVICE
3	CROSS_DEVICE_PENDING + NEW_IP + UNRECOGNIZED_DEVICE
2	UNRECOGNIZED_DEVICE
2	NEW_IP
2	NEW_IP + UNRECOGNIZED_DEVICE + CONSECUTIVE_FAILURES
2	IP_BLACKLISTED

6) الخلاصة

- السيناريو 1 غير صالح لمصادقة حقيقية: يقيس خط الأساس فقط للمقارنة.
- السيناريو 2 هو التوازن العملي: يوقف أكثر أنواع الاختراق شيوعًا (رمز مسروق) بتكلفة خطوة واحدة.
- السيناريو 3 هو الأعلى أمنًا، ويُستخدم حين تكون الحسابات حساسة (مشرف/إداري) أو عند وجود مؤشرات خطورة فعلية مثل IMPOSSIBLE_TRAVEL.
- النظام يختار تصعيّدًا تدريجيًا لا تحققًا ثابتًا: يبدأ السيناريو الذي يختاره المستخدم، ويرفع المتطلبات تلقائيًا عندما ترتفع درجة الخطر.